

LEARNING RESOURCE GUIDE
ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional
Participant Workbook

Cloud Audit Processes: Internal and External Controls

1. Learning Objectives

By the end of this lecture, you will be able to:

- Explain why traditional on-premises audit approaches require modification in cloud environments.
- Distinguish internal controls from external controls and describe the role of each in cloud compliance programmes.
- Classify preventive, detective, and corrective controls and give cloud-specific examples of each.
- Describe how virtualisation and multi-tenancy create specific audit challenges and how they are addressed.
- Explain audit rights clauses, scope restrictions in third-party audit reports, and the shared responsibility model as an audit framework.

2. Introduction

During a regulatory examination of a major European bank, the examiner asked to review audit evidence for the bank's cloud-hosted core banking platform. The bank produced a SOC 2 Type II report from its cloud provider. The examiner reviewed the report's scope section and identified that the specific service tier the bank was using — a dedicated hosting environment rolled out 14 months earlier — was not listed among the in-scope systems. The report covered the provider's general infrastructure but not the configuration the bank actually relied on. The bank had no other audit evidence for that environment. The compliance team had assumed the SOC 2 report covered everything. It covered everything in scope. Their environment was not in scope.

This scenario plays out across industries. Cloud audit processes are widely misunderstood — often because the mental model for what an audit is and who conducts it was built for on-premises environments where an auditor could physically inspect the systems being assessed. In the cloud, that direct access is largely unavailable. The infrastructure is abstracted, shared, and managed by a third party. Audit evidence takes a different form, and the cloud customer's role in producing and evaluating that evidence is fundamentally different.

This lecture works through cloud audit processes from two angles — internal controls that the organisation designs and operates, and external controls provided by third-party assurance mechanisms — and examines the specific complications that virtualisation and

multi-tenancy introduce. Understanding both the mechanics and the limitations of cloud auditing is essential to operating a credible cloud compliance programme.

3. Core Concepts Explained

What Cloud Auditing Is and Why It Differs

An audit is a systematic examination of evidence to determine whether an organisation's systems, processes, and controls are operating as intended and in compliance with applicable standards. In traditional on-premises environments, auditors could directly inspect physical hardware, review log files on systems they accessed themselves, and observe operational processes. In cloud environments, much of that direct access is unavailable to both the cloud customer and its auditors.

The infrastructure is managed by a provider, in facilities the customer may never visit, running software stacks the customer cannot fully inspect. The cloud customer cannot verify that data is being stored only in approved locations, that deprovisioned storage volumes are being securely wiped, or that the hypervisor layer is configured as represented — not through direct inspection. Instead, assurance comes through a chain of evidence: the provider's own controls, independently verified by third-party auditors, documented in reports the customer reviews, assessed against the customer's own requirements.

Internal Controls

Internal controls are the policies, procedures, and technical mechanisms an organisation puts in place to manage its own risks. They are designed and operated by the organisation itself, or by an internal audit function that reports within the organisation. In cloud environments, internal controls cover access management, change management, logging and monitoring, data handling, incident response, and vendor oversight.

A well-designed internal control environment includes three categories of controls. Preventive controls stop problems from occurring. In cloud environments, preventive controls include multi-factor authentication required before administrative access, configuration baselines that prevent insecure deployments, infrastructure-as-code templates that enforce approved settings, and just-in-time access provisioning that limits standing administrative privileges. Detective controls identify problems that have already occurred. Cloud detective controls include log aggregation and SIEM alerting, anomaly detection in access and API activity, periodic access reviews comparing actual permissions to approved roles, and configuration drift alerts. Corrective controls restore normal operations after a problem is detected. Cloud corrective controls include automated remediation scripts that restore configurations when drift is detected, incident response playbooks, and backup and recovery procedures.

A critical consideration: internal controls designed for on-premises environments often need redesign for the cloud. Network segmentation that relied on physical switches must be reimplemented using cloud-native security groups or software-defined networking policies. Physical access controls that prevented unauthorised individuals from reaching servers are

replaced by identity-based controls governing who can interact with cloud management APIs. The control objective is typically the same — isolate sensitive workloads, prevent unauthorised access, detect configuration changes — but the implementation mechanism changes substantially.

External Controls

External controls refer to oversight mechanisms that originate outside the organisation. These include external audits conducted by independent third parties, regulatory inspections, and certifications or assessments produced by accredited bodies. External controls provide independent assurance — verification that the organisation's systems are actually performing as claimed by someone with no organisational stake in the outcome.

In cloud environments, external controls most commonly take the form of certifications and audit reports that cloud service providers produce and make available to customers. The most widely used include SOC 2 Type II reports, which assess the design and operating effectiveness of controls related to security, availability, processing integrity, confidentiality, and privacy over a defined period. ISO/IEC 27001 certifications demonstrate that the provider has implemented a certified information security management system. FedRAMP authorisations attest that the provider meets US federal security requirements for cloud services. CSA STAR assessments demonstrate compliance with the Cloud Security Alliance's Cloud Controls Matrix.

These third-party reports are the mechanism through which cloud customers gain assurance about provider controls without performing their own audits of provider infrastructure. The customer reviews the reports, maps the controls covered to its own compliance requirements, identifies any gaps, and takes responsibility for the portions of the shared responsibility model that fall within its own domain.

Virtualisation and Multi-Tenancy Audit Challenges

Virtualisation and multi-tenancy create audit challenges that have no direct parallel in on-premises environments. In a physical environment, the boundary between one organisation's systems and another's is a physical boundary. In the cloud, that boundary is logical: multiple customers run workloads on the same physical hardware, separated by software controls. The hypervisor, network virtualisation layer, and cloud management plane are shared infrastructure. If any of those layers contains a vulnerability, multiple tenants may be affected simultaneously.

From an audit perspective, the customer cannot directly audit the shared infrastructure. It cannot inspect the hypervisor configuration, verify that storage is securely wiped on deprovisioning, or confirm that network isolation is operating correctly at the hardware level. The customer is dependent on the provider's controls — and those controls must be backed by credible, independent audit evidence. This is why the SOC 2 report, the ISO/IEC 27001 certificate, and the FedRAMP authorisation exist: they provide the independent verification the customer cannot obtain through direct inspection.

Another specific challenge: virtual machine sprawl. In on-premises environments, spinning up a new server requires procurement, physical installation, and IT team involvement — creating natural checkpoints. In the cloud, authorised users can provision compute instances in minutes, sometimes without formal change management approval. If the internal control environment does not account for cloud-native resource provisioning, the organisation may find itself running workloads it never formally approved, not logged in its change management system, and outside the scope of its security controls.

Audit Rights and Right-to-Audit Clauses

A right-to-audit clause in a cloud contract gives the customer the contractual authority to conduct or commission an audit of the provider's controls. In practice, major cloud providers rarely grant individual customers the ability to physically inspect their facilities — the operational disruption across thousands of concurrent customers would be unmanageable. Instead, providers offer substitutes: access to third-party audit reports, participation in shared security assessments, dedicated compliance documentation portals, and in some cases, independent assessment programmes where accredited auditors assess the provider on the customer's behalf.

For the CCSP exam, understanding what right-to-audit substitutes are acceptable is important. A SOC 2 Type II report produced by an independent auditor is widely accepted as a substitute for a customer-conducted audit. The customer must verify that the report's scope includes the specific services and regions being used, that the period covered is current, and that the controls tested map to the customer's own requirements. Where gaps exist — services or regions not in scope, controls not tested, recent changes not reflected — the customer must address those gaps through other means, such as contractual commitments or additional technical assessments.

Audit Scope Restrictions

When a cloud provider produces an audit report, that report covers a specific set of services, systems, and time periods. It does not automatically cover everything the customer uses. This is the most common source of false assurance in cloud compliance programmes: a customer assumes its workload is covered by a SOC 2 report when the specific service or region it uses was not included in that report's scope.

Scope restrictions must be verified before relying on any third-party audit report for compliance purposes. The scope section of the report will list the specific services, systems, geographies, and time period covered. If the customer's deployment uses services not in scope, the customer must obtain separate assurance for those components through alternative means, or negotiate with the provider to include them in future assessment cycles.

Shared Responsibility as an Audit Framework

The shared responsibility model is not only a technical framework for dividing security duties between provider and customer. It is equally an audit framework. The customer is responsible for auditing the components within its own domain: identity and access

management configuration, application security, data classification and protection, network controls the customer configures, and workload security. The provider is responsible for auditing the infrastructure layer: physical security, hypervisor controls, network infrastructure, and core platform security. The customer obtains assurance about the provider's layer through third-party reports and certifications.

The assurance chain in cloud auditing runs from the customer's internal controls, through the provider's independently verified controls, to the contractual commitments that bind them together. Understanding each link — and recognising where the chain can break — is precisely what the CCSP exam expects candidates to evaluate.

4. Control Type Comparison Table

Control Type	Purpose	Cloud Example
Preventive	Stop security problems before they occur	MFA on management console, IaC templates enforcing approved configurations, just-in-time access
Detective	Identify problems that have already occurred	SIEM alerting on API anomalies, access reviews, configuration drift detection, CloudTrail logging
Corrective	Restore normal operations after an incident	Auto-remediation scripts, incident response playbooks, snapshot restoration, account quarantine
Compensating	Satisfy a control requirement when the primary control is unavailable	Enhanced monitoring where encryption is infeasible; additional logging where access cannot be restricted

5. External Audit Report Types

Report / Certification	Issuing Body / Standard	What It Demonstrates
SOC 2 Type I	AICPA (independent CPA firm)	Controls are suitably designed at a point in time
SOC 2 Type II	AICPA (independent CPA firm)	Controls are designed and operating effectively over a defined period (typically 6-12 months)
ISO/IEC 27001	Accredited certification body	Information security management system meets ISO standard requirements
FedRAMP Authorization	US government (FedRAMP PMO)	Cloud service meets US federal security requirements; enables

		government agencies to use the service
CSA STAR	Cloud Security Alliance	Compliance with CSA Cloud Controls Matrix; available at multiple levels of assurance

6. Real-World Incident

Incident: In 2019, Capital One experienced one of the largest financial data breaches in US history, exposing over 100 million customer records stored in a cloud environment. The attacker exploited a misconfigured web application firewall to extract data from cloud storage buckets. Post-incident investigation revealed that while the cloud provider's infrastructure was secure and its SOC 2 and other audit certifications were valid, the misconfiguration responsible for the breach fell entirely within Capital One's own domain under the shared responsibility model. The provider's audit reports did not and could not cover the customer's application-layer configuration. Capital One's internal controls — specifically, its processes for detecting and remediating cloud misconfigurations — failed to identify the exposure before the breach occurred. The incident reinforced that external audit evidence about provider controls does not substitute for robust internal controls over customer-managed configuration.

7. Analogy

Think of cloud auditing as a relay race, not a solo sprint. The cloud provider runs the first leg: securing the physical infrastructure, hypervisor, and platform. An independent third-party auditor verifies the provider's leg and produces a report you can read. You run the second leg: configuring the services, managing access, protecting your data, and monitoring your workloads. Your internal audit team and external auditors verify your leg. No runner can cover the whole track. Each leg must be run well, and each handoff — represented by the contract and the shared responsibility model — must be clean. Dropping the baton at the handoff is where most cloud compliance failures occur.

8. Exam Focus

Cloud audit processes appear throughout the CCSP exam. Key distinctions and concepts to retain:

- Internal controls are designed and operated by the organisation. External controls provide independent third-party assurance.
- Preventive, detective, and corrective are the three primary control categories; understand cloud-specific examples of each.
- Virtualisation and multi-tenancy mean the customer cannot directly audit the hypervisor or shared infrastructure layer.
- SOC 2 Type I assesses control design at a point in time. SOC 2 Type II assesses design and operating effectiveness over a period.
- Scope restrictions in audit reports are critical. Always verify that the specific service, region, and time period are covered.

- Right-to-audit clauses are common in cloud contracts but rarely mean physical facility access for individual customers. SOC 2 and similar reports are the accepted substitute.
- The shared responsibility model defines audit responsibilities: customer audits customer-managed controls; provider's controls are verified through third-party reports.
- VM sprawl is a cloud-specific internal control challenge where resource provisioning outpaces change management and logging processes.
- False assurance is a common risk: customers assume a provider's audit report covers their specific deployment when it does not.

9. Key Terms Glossary

Internal Controls: Policies, procedures, and technical mechanisms an organisation designs and operates to manage its own risks and compliance obligations.

External Controls: Independent oversight mechanisms including third-party audits, regulatory inspections, and certifications that provide assurance about controls from outside the organisation.

Preventive Control: A control that stops a security or compliance problem from occurring.

Detective Control: A control that identifies a security or compliance problem that has already occurred.

Corrective Control: A control that restores normal operations after a security or compliance problem is detected.

SOC 2 Type II: A third-party audit report assessing the design and operating effectiveness of an organisation's controls related to security, availability, processing integrity, confidentiality, and privacy over a defined period.

FedRAMP: US Federal Risk and Authorization Management Program providing a standardised approach to security assessment, authorisation, and monitoring for cloud services used by US federal agencies.

Right-to-Audit Clause: A contractual provision giving the customer authority to conduct or commission an audit of the cloud provider's controls.

Audit Scope Restriction: A limitation in a third-party audit report that defines the specific services, systems, regions, or time period covered, excluding everything else from the assurance provided.

VM Sprawl: The uncontrolled proliferation of virtual machine instances in a cloud environment, creating workloads outside change management and security monitoring processes.

10. Quick Revision Checklist

- ☐ I can explain why cloud auditing differs from on-premises auditing and what replaces direct system access.
- ☐ I can distinguish internal controls from external controls and give examples of each in a cloud context.
- ☐ I can classify a given control as preventive, detective, or corrective and provide a cloud-specific example.
- ☐ I understand how virtualisation and multi-tenancy complicate auditing by removing direct access to shared infrastructure.
- ☐ I know the difference between SOC 2 Type I and SOC 2 Type II and what each assesses.
- ☐ I understand that audit scope restrictions may exclude the specific services or regions a customer uses.
- ☐ I can explain what a right-to-audit clause is and why physical access substitutes such as SOC 2 reports are typically used instead.
- ☐ I understand the shared responsibility model as an audit framework defining who is responsible for which controls.
- ☐ I know that internal controls must be redesigned for cloud environments where on-premises assumptions no longer hold.
- ☐ I can identify VM sprawl as a cloud-specific challenge to internal control coverage.

11. Practice MCQs

Question 1

SCENARIO: A financial services organisation engages an external auditor to review its cloud compliance programme. The auditor asks to review the cloud provider's SOC 2 Type II report. After reviewing the scope section, the auditor notes that the object storage service used for customer document archiving is not listed as an in-scope system. Which of the following best describes the implication of this finding?

A) The SOC 2 report provides assurance for all of the provider's services; scope sections list optional inclusions only.

Explanation: Incorrect. Scope sections in SOC 2 reports define the precise boundaries of the assurance provided. Systems or services not listed are not covered. The report provides no assurance about out-of-scope components.

B) The organisation has a gap in its external assurance chain for the object storage service and must obtain separate evidence for that component.

Explanation: Correct. Audit reports only cover what is within their defined scope. The object storage service falls outside the assurance provided by this report. The organisation must obtain additional assurance — through a supplemental assessment, contractual commitments, or a separate report — for that service.

C) The organisation should ask the auditor to expand the scope of the SOC 2 report to include the object storage service.

Explanation: Incorrect. An external audit report cannot be unilaterally expanded by the customer or its auditor. The scope of a provider's SOC 2 report is determined by the provider and its independent auditor. The customer must either accept the scope as-is or seek additional assurance through other means.

D) The provider's ISO/IEC 27001 certification covers the object storage service and fills the gap.

Explanation: Incorrect. ISO/IEC 27001 certifies the provider's ISMS but does not provide the operational control effectiveness assurance that a SOC 2 Type II report provides. And like the SOC 2 report, the ISO/IEC 27001 certificate would also need to be checked for scope.

Question 2

An organisation implements a cloud security policy requiring that all administrative access to production environments must be requested in real time, approved by a second administrator, granted for a maximum of four hours, and automatically revoked thereafter. Which control type does this policy primarily represent?

A) Detective control, because it detects when administrators access production environments.

Explanation: Incorrect. This policy prevents standing access from existing — it stops unauthorised access before it occurs rather than detecting access after the fact.

B) Corrective control, because it revokes access after the four-hour window.

Explanation: Incorrect. Corrective controls respond to problems that have already occurred. Automatic revocation is a feature of the access policy design, not a response to a detected incident.

C) Preventive control, because it prevents standing administrative access and limits the scope and duration of any granted access.

Explanation: Correct. Just-in-time access with approval gates and automatic revocation is a preventive control. It prevents the risk of standing administrative credentials being compromised or misused by ensuring no persistent elevated access exists.

D) Compensating control, because it replaces permanent access credentials with temporary ones.

Explanation: Incorrect. Compensating controls are implemented when a primary control cannot be applied. This policy is the primary access control design, not a workaround for an inability to implement another control.

Question 3

SCENARIO: A cloud security manager is reviewing the organisation's audit strategy for a multi-tenant cloud deployment. An internal auditor suggests that because the organisation's

workloads run on shared physical hardware with other tenants, it should directly inspect the hypervisor layer to verify isolation controls. Which response is most accurate?

A) Direct hypervisor inspection is feasible and should be included in the internal audit plan.

Explanation: Incorrect. Cloud customers do not have access to the hypervisor layer in multi-tenant environments. Direct inspection of shared infrastructure is not available to cloud customers.

B) Direct hypervisor inspection is not possible for cloud customers; assurance about the hypervisor layer must come from the provider's independent audit reports and certifications.

Explanation: Correct. In multi-tenant cloud environments, hypervisor controls are the provider's responsibility and are not accessible to individual customers. Assurance is obtained through third-party reports such as SOC 2 Type II and ISO/IEC 27001 certifications that cover the hypervisor and platform layer.

C) The organisation can inspect the hypervisor by invoking the right-to-audit clause in its cloud contract.

Explanation: Incorrect. Right-to-audit clauses give customers the contractual right to audit but do not translate to direct hypervisor access. Providers substitute third-party reports for individual customer audits of shared infrastructure.

D) Multi-tenancy eliminates the need for hypervisor auditing because logical separation provides equivalent assurance to physical separation.

Explanation: Incorrect. Logical separation through virtualisation requires its own audit and assurance. The need for hypervisor security assurance is not eliminated by multi-tenancy — it is heightened.

Question 4

What is the primary difference between a SOC 2 Type I and a SOC 2 Type II report?

A) SOC 2 Type I covers security and availability; SOC 2 Type II covers confidentiality and privacy.

Explanation: Incorrect. Both Type I and Type II SOC 2 reports may cover any of the five Trust Services Criteria: security, availability, processing integrity, confidentiality, and privacy. The difference is not which criteria are covered.

B) SOC 2 Type I assesses whether controls are suitably designed at a point in time; SOC 2 Type II assesses both design and operating effectiveness over a defined period.

Explanation: Correct. A Type I report confirms that controls were designed appropriately as of a specific date. A Type II report confirms that controls were designed appropriately and operated effectively over a defined period, typically six to twelve months, providing significantly stronger assurance.

C) SOC 2 Type I is conducted by the organisation's internal auditors; SOC 2 Type II is conducted by an independent external firm.

Explanation: Incorrect. Both Type I and Type II SOC 2 reports are conducted by independent licensed CPA firms. Neither is an internal audit.

D) SOC 2 Type I applies to cloud providers; SOC 2 Type II applies to cloud customers.

Explanation: Incorrect. SOC 2 reports can be produced by any service organisation — including cloud providers — for both types. Cloud customers typically review their provider's SOC 2 reports; customers do not typically produce SOC 2 reports about themselves for provider review.

Question 5

SCENARIO: A healthcare organisation's cloud security team discovers that 47 virtual machine instances have been provisioned in a production cloud environment over the past three months without corresponding entries in the change management system. The instances are running workloads that process patient data but are not included in the organisation's security monitoring configuration. Which control gap does this scenario most directly illustrate?

A) Inadequate encryption controls for virtual machine storage volumes.

Explanation: Incorrect. The scenario does not describe an encryption failure. The gap is about visibility, tracking, and control coverage for untracked provisioned resources.

B) VM sprawl resulting from insufficient internal controls over cloud resource provisioning and change management integration.

Explanation: Correct. VM sprawl occurs when cloud resource provisioning outpaces change management processes, creating workloads outside the organisation's security monitoring and control coverage. This is a classic cloud-specific internal control challenge with no direct on-premises analogue at the same speed and scale.

C) A deficiency in the cloud provider's external audit programme, which should have detected the unauthorised instances.

Explanation: Incorrect. Cloud provider audit programmes cover provider-managed infrastructure. The customer's resource provisioning decisions and change management processes are within the customer's domain under the shared responsibility model. This is a customer-side control failure.

D) Absence of multi-factor authentication on administrative accounts, allowing unauthorised provisioning.

Explanation: Incorrect. The scenario does not indicate that the instances were provisioned without authorisation from an account control perspective. The gap is that authorised users provisioned instances outside the change management process, and the security monitoring configuration was not updated to include them.

Question 6

An organisation negotiates a right-to-audit clause with a cloud provider. The provider's response is to offer access to its third-party SOC 2 Type II report, compliance documentation portal, and participation in an annual shared assessment programme, but

declines to permit physical facility inspections by individual customers. Which of the following best characterises this outcome?

A) The provider is in breach of the right-to-audit clause, and the customer should seek a provider that permits physical inspections.

Explanation: Incorrect. Right-to-audit clauses in cloud contracts typically acknowledge that physical facility inspections of shared infrastructure are impractical for individual customers. Third-party audit reports are widely accepted as the industry-standard substitute.

B) The provider's offer of third-party audit reports and shared assessments represents the industry-standard fulfilment of audit rights in cloud environments.

Explanation: Correct. Major cloud providers serve thousands of customers. Permitting individual physical audits would create unmanageable operational disruption. The standard approach — providing access to independent third-party audit reports and participating in shared assessment programmes — is broadly accepted by regulators and industry frameworks as an appropriate substitute for individual customer audits.

C) The organisation has no audit rights because the provider declined physical access; the right-to-audit clause is unenforceable.

Explanation: Incorrect. The right-to-audit clause remains enforceable. The provider is fulfilling it through alternative means that the clause should anticipate. Many right-to-audit clauses in cloud contracts explicitly describe the substitute mechanisms.

D) The organisation must conduct a penetration test of the provider's infrastructure to obtain the assurance it needs.

Explanation: Incorrect. Customer-initiated penetration testing of cloud provider infrastructure is typically prohibited by cloud service agreements and would not constitute fulfilment of audit rights. Penetration testing within the customer's own cloud environment, governed by the provider's testing policy, is a separate matter.

Question 7

Which of the following best describes the relationship between the shared responsibility model and cloud audit processes?

A) The shared responsibility model assigns all audit responsibility to the cloud provider; the customer is responsible only for reviewing the provider's reports.

Explanation: Incorrect. The shared responsibility model divides responsibilities between provider and customer. The customer is responsible for auditing and demonstrating control effectiveness within its own domain: identity, access, application, and data controls.

B) The shared responsibility model functions as an audit framework: the customer audits customer-managed controls, while provider controls are verified through independent third-party reports reviewed by the customer.

Explanation: Correct. The shared responsibility model defines which controls belong to which party, and this directly maps to audit responsibilities. The customer designs,

operates, and audits its controls. The customer then reviews the provider's independently verified controls through audit reports, certifications, and assessments.

C) The shared responsibility model requires the customer's internal audit team to audit the provider's infrastructure quarterly.

Explanation: Incorrect. Customer internal audit teams do not have access to audit cloud provider infrastructure directly. Provider infrastructure assurance comes from the provider's own independent third-party audit reports.

D) The shared responsibility model eliminates the customer's audit obligations by transferring all security responsibility to the provider.

Explanation: Incorrect. No cloud service model eliminates the customer's audit obligations. Even in Software-as-a-Service deployments, customers retain responsibility for identity management, access controls, and data handling.

Question 8

A cloud security architect is designing a control to address the risk that cloud storage buckets containing sensitive data might be accidentally configured as publicly accessible. Which control type would most directly address this risk?

A) Detective control: alert the security team when a storage bucket is configured as public.

Explanation: Incorrect. A detective control identifies the exposure after it has been configured. The risk is that public exposure may persist between the configuration event and the alert being acted upon.

B) Preventive control: enforce an organisation-wide policy that blocks the creation or modification of storage buckets to a public access configuration.

Explanation: Correct. A preventive control stops the misconfiguration from occurring. Cloud-native tools allow organisations to enforce policies at the account or organisation level that block public access settings on storage buckets, preventing the risk from materialising rather than detecting it after the fact.

C) Corrective control: automatically restore bucket access settings to private after any public configuration is detected.

Explanation: Incorrect. A corrective control responds to an incident that has already occurred. The bucket would be publicly accessible from the moment of misconfiguration until the corrective action fires — potentially exposing data. A preventive control addresses the risk earlier in the sequence.

D) Compensating control: encrypt all data in storage buckets to render public access harmless.

Explanation: Incorrect. Encryption reduces the impact of a public exposure but does not prevent it. A compensating control is used when the primary control cannot be applied; here, a preventive control is both feasible and preferable.

Question 9

Which of the following cloud-specific scenarios represents a control design challenge that would not exist in a traditional on-premises environment?

A) The need for user identity verification before system access is granted.

Explanation: Incorrect. Identity verification before access is a fundamental control requirement in both on-premises and cloud environments. It is not cloud-specific.

B) Authorised developers can provision production compute instances directly through a cloud API in seconds, creating workloads outside the change management and security monitoring process.

Explanation: Correct. The self-service, API-driven nature of cloud environments allows resource provisioning at a speed and by a population (developers with API access) that on-premises environments do not support. This creates a cloud-specific control challenge: ensuring that rapid, distributed provisioning is captured by change management and security monitoring before workloads process real data.

C) The need to patch operating systems on production servers.

Explanation: Incorrect. Operating system patching is required in both on-premises and cloud environments. While cloud environments have different patching mechanisms, the underlying control requirement is not cloud-specific.

D) The requirement to maintain audit logs of administrative access.

Explanation: Incorrect. Audit logging of administrative access is required in both on-premises and cloud environments. Cloud environments may change how logs are generated and stored, but the control requirement predates cloud computing.

Question 10

SCENARIO: A CCSP candidate is asked to evaluate a cloud compliance programme. The organisation has a valid SOC 2 Type II report for its cloud provider, ISO/IEC 27001 certification for its own ISMS, and a documented internal control framework covering access management, logging, and incident response. However, during a review of a recent security incident, the team discovers that a misconfigured security group allowed direct internet access to a database server containing customer data for 11 days before detection. Which component of the audit programme most directly failed?

A) The cloud provider's external controls failed, because the SOC 2 report should have detected the misconfiguration.

Explanation: Incorrect. Security group configuration is a customer-managed control under the shared responsibility model. The provider's SOC 2 report covers provider-managed infrastructure, not the customer's network access configurations.

B) The organisation's detective internal controls failed, because a misconfiguration that exposed a customer database to the internet for 11 days should have been identified and remediated far sooner.

Explanation: Correct. Security group misconfigurations are within the customer's control

domain. The organisation's detective controls — configuration drift alerting, CSPM tools, or manual review processes — should have identified the open access setting before 11 days elapsed. The failure is in the customer's own internal audit and monitoring programme.

C) The ISO/IEC 27001 certification failed to cover the misconfiguration, indicating a gap in the certification scope.

Explanation: Incorrect. ISO/IEC 27001 certifies the design and implementation of an ISMS. It does not provide real-time detection of configuration drift. A certification covering the ISMS scope is not the mechanism for identifying a specific misconfiguration in a cloud environment.

D) The incident indicates the right-to-audit clause should have been exercised to inspect the provider's network controls.

Explanation: Incorrect. The misconfigured security group was a customer-managed resource, not a provider-managed one. Auditing the provider's network controls would not have identified a misconfiguration within the customer's own environment.